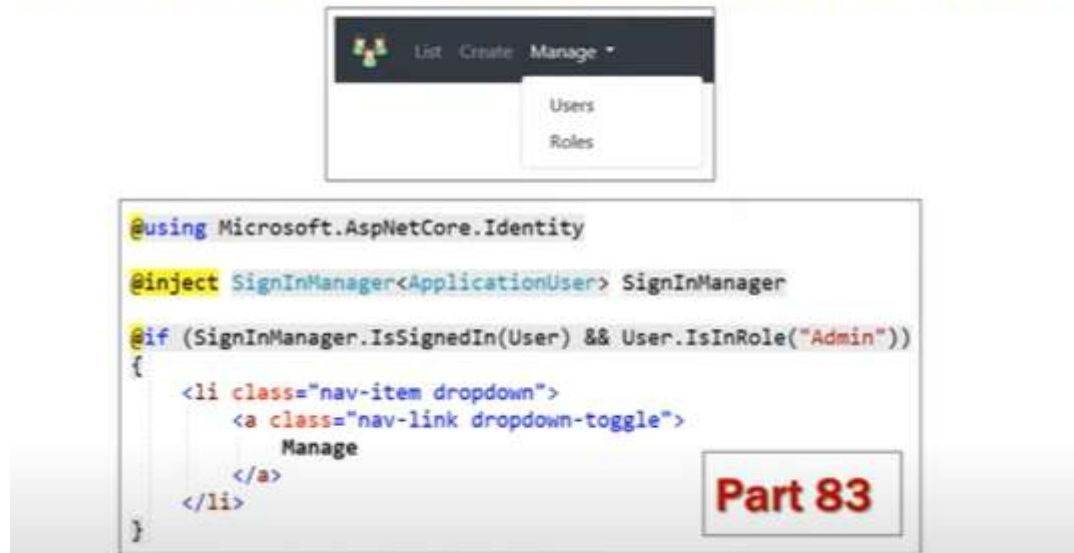


96 - Authorization in views

Много удобна техника, когато искаме да показваме/скриваме UI елементи в зависимост от достъпа на потребителите. Например меню Manage е видимо само за админ:

Role Based Authorization Check in Views



Искаме бутон Edit да бъде видим и достъпен само за админи, а като самостоятелно упражнение и Delete:

All Roles

Add new role

Role Id : 71ef2a67-38d4-42e5-88c0-2847ce6f6ca0

User

Edit

Delete

```
services.AddAuthorization(options =>
{
    options.AddPolicy("DeleteRolePolicy",
        policy => policy.RequireClaim("Delete Role"));

    options.AddPolicy("EditRolePolicy",
        policy => policy.RequireClaim("Edit Role"));

    options.AddPolicy("AdminRolePolicy",
        policy => policy.RequireRole("Admin"));
});
```

За целта, първо трябва да вмъкнем необходимите

```
AdministrationController.cs  ListRoles.cshtml  X
@model IEnumerable<IdentityRole>

@using Microsoft.AspNetCore.Authorization
@inject IAuthorizationService authorizationService;
```

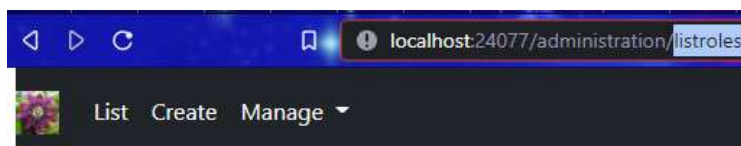
```
@using Microsoft.AspNetCore.Authorization
@inject IAuthorizationService authorizationService;
```

Ограждаме Edit бутон с if блок:

```
@if ((await authorizationService.AuthorizeAsync(User, "EditRolePolicy")).Succeeded)
{
    <a asp-controller="Administration" asp-action="EditRole"
      asp-route-id="@role.Id" class="btn btn-primary">
        Edit
    </a>
}
```

```
@if ((await authorizationService.AuthorizeAsync(User, "EditRolePolicy")).Succeeded)
{
    <a asp-controller="Administration" asp-action="EditRole"
      asp-route-id="@role.Id" class="btn btn-primary">
        Edit
    </a>
}
```

Резултат:



All Roles

Add new role

Role Id : 71ef2a67-38d4-42e5-88c0-2847ce6f6ca0

User

Delete

Потребителят няма видимост към Edit бутона, но може да получи достъп чрез адресиране:

Като промяната user->user1 се приема от системата, т.е. скриването на елементи не е достатъчно.

Трябва да защитим и съответните Controller actions.

```
[HttpGet]
[Authorize(Policy = "EditRolePolicy")]
0 references
public async Task<IActionResult> EditRole(string id)
```

```
[HttpPost]
[Authorize(Policy = "EditRolePolicy")]
0 references
public async Task<IActionResult> EditRole(EditRoleViewModel model)
```

При тази ситуация, ако се опитаме директно от URL да въведем редакция на потребителя, достъпът се отказва:

Account/AccessDenied?ReturnUrl=%2FAdministration%2FEditRole%2F71ef2a67-38d4-42e5-88c0-2847ce6f6ca0

Access Denied

You do not have permission to view this resource



If you need [IAuthorizationService](#) in multiple views, consider importing in [_ViewImports.cshtml](#), so you do not have to import it in every individual view.

Claims Based Authorization Check in Views

list Create Manage *

All Roles

Add new role

Role Id : 2a24bc5c-db50-4940-aed9-2c639dc74aed

Test Role

Edit Delete

Part 31

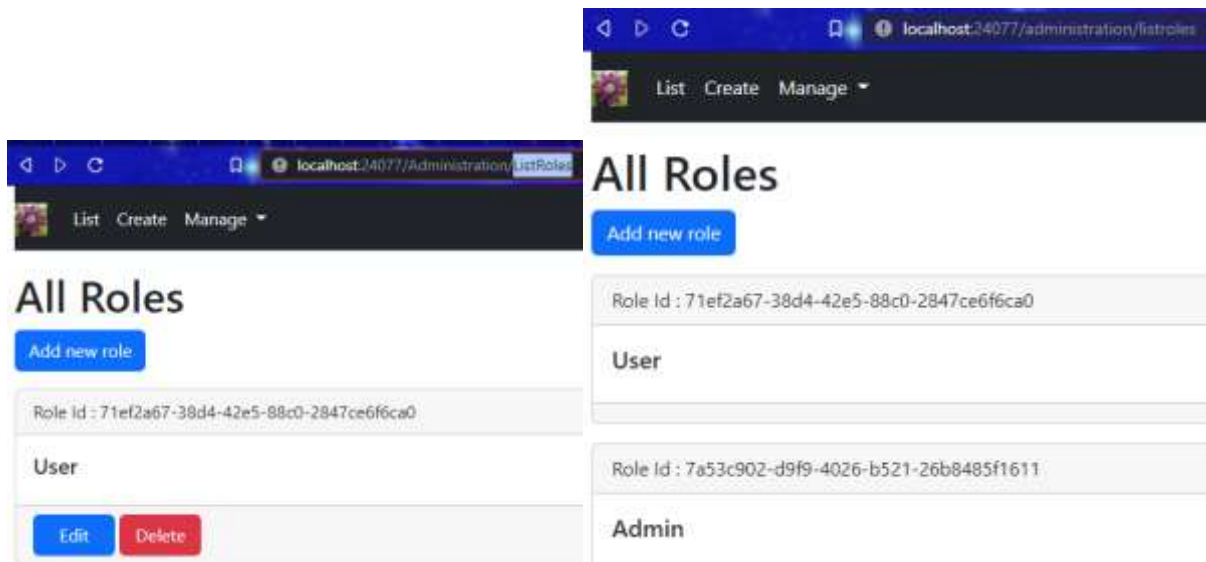
_ViewImports

```
@model IEnumerable<IdentityRole>
@using Microsoft.AspNetCore.Authorization
@inject IAuthorizationService authorizationService;

@if ((await authorizationService.AuthorizeAsync(User, "EditRolePolicy")).Succeeded)
{
    <a asp-controller="Administration" asp-action="EditRole"
      asp-route-id="@role.Id" class="btn btn-primary">
        Edit
    </a>
}
}
```

Упражнение: оставям само админ Aurora да има 3-те Claims с достъп до edit + delete Roles.

Bob = admin, Create + Edit Claims.



Скривам бутон Delete за всеки без достъп до Delete Roles Policy:

```
[HttpGet]
[Authorize(Policy = "EditRolePolicy")]
[Authorize(Policy = "DeleteRolePolicy")]
0 references
public async Task<IActionResult> EditRole(string id)
```

```
[HttpPost]
[Authorize(Policy = "EditRolePolicy")]
[Authorize(Policy = "DeleteRolePolicy")]
```

```
ListRoles.cshtml
<div class="card-footer">
    @if ((await authorizationService.AuthorizeAsync(User, "EditRolePolicy", "DeleteRolePolicy")).Succeeded)
    {
        <form asp-action="DeleteRole" asp-route-id="@role.Id" method="post">
            <a asp-controller="Administration" asp-action="EditRole"
              asp-route-id="@role.Id" class="btn btn-primary">
                Edit
            </a>

            <span id="confirmDeleteSpan_@role.Id" style="display:none">
                <span>Are you sure you want to delete?</span>
                <button type="submit" class="btn btn-danger">Yes</button>
                <a href="#" class="btn btn-primary"
                  onclick="confirmDelete('@role.Id', false)">No</a>
            </span>

            <span id="deleteSpan_@role.Id">
                <a href="#" class="btn btn-danger"
                  onclick="confirmDelete('@role.Id', true)">Delete</a>
            </span>
        </form>
    }
</div>
```

```
<div class="card-footer">
    @if ((await authorizationService.AuthorizeAsync(User,
"EditRolePolicy", "DeleteRolePolicy")).Succeeded)
    {
```



```
<form asp-action="DeleteRole" asp-route-id="@role.Id" method="post">

    <a asp-controller="Administration" asp-action="EditRole"
      asp-route-id="@role.Id" class="btn btn-primary">
      Edit
    </a>

    <span id="confirmDeleteSpan_@role.Id" style="display:none">
      <span>Are you sure you want to delete?</span>
      <button type="submit" class="btn btn-danger">Yes</button>
      <a href="#" class="btn btn-primary"
        onclick="confirmDelete('@role.Id', false)">No</a>
    </span>

    <span id="deleteSpan_@role.Id">
      <a href="#" class="btn btn-danger"
        onclick="confirmDelete('@role.Id', true)">Delete</a>
    </span>
</form>
}
</div>
```